

EAP External Application Integration Guide

Tài liệu này liệt kê protocol, endpoint, credential, RabbitMQ topology và payload contract để application tích hợp với EAP. Application tự chọn framework và thư viện; cách implement các standard protocol tham khảo tài liệu chính thức tương ứng.

EAP cấp value theo từng environment. Tên EAP_* trong tài liệu là tên env gợi ý; application có thể map sang tên riêng. Redirect URI do application đề xuất và EAP đăng ký/duyet.

1. Authentication - OIDC SSO

Mục đích: cho phép user đăng nhập application bằng tài khoản EAP và tạo local session cho application.

Protocol

Hạng mục	Contract
Standard	OpenID Connect
User login	Authorization Code Flow + PKCE S256
Client profile	Confidential Web/BFF hoặc Public SPA theo đăng ký
Client authentication	None, client secret hoặc PrivateKeyJwt theo profile
API/resource	Resource/audience và scope do EAP cấp/duyet

EAP cấp hoặc đăng ký

Env key gợi ý	EAP cấp/duyet	Secret
EAP_OIDC_ISSUER	Issuer URL	Không
EAP_OIDC_DISCOVERY_URL	OIDC discovery URL	Không
EAP_OIDC_CLIENT_ID	Client ID theo application/environment	Không
EAP_OIDC_CLIENT_AUTH_METHOD	None, client secret hoặc PrivateKeyJwt	Không
EAP_OIDC_CLIENT_SECRET	Client secret nếu client profile yêu cầu	Có
EAP_OIDC_PRIVATE_KEY_REF	Key reference/configuration nếu dùng PrivateKeyJwt	Có
EAP_OIDC_REDIRECT_URI	Redirect URI đã đăng ký chính xác	Không
EAP_OIDC_POST_LOGOUT_REDIRECT_URI	Post-logout URI đã đăng ký	Không
EAP_OIDC_SCOPES	Scope được approve, ví dụ openid profile email offline_access	Không
EAP_API_RESOURCE	API resource/audience được cấp nếu gọi API	Không

Endpoint

Application lấy endpoint từ EAP_OIDC_DISCOVERY_URL; không hard-code theo hostname:

Discovery field	Dùng cho
authorization_endpoint	Redirect user login
token_endpoint	Exchange authorization code và refresh token

Discovery field	Dùng cho
userinfo_endpoint	Profile lookup nếu cần
end_session_endpoint	Kết thúc EAP SSO session
jwks_uri	Public signing keys cho JWT validation

Request mẫu:

```
GET {authorization_endpoint}?
  client_id={EAP_OIDC_CLIENT_ID}
  &response_type=code
  &redirect_uri={registered_redirect_uri}
  &scope={approved_scopes}
  &state={state}
  &nonce={nonce}
  &code_challenge={code_challenge}
  &code_challenge_method=S256
```

Token endpoint dùng `grant_type=authorization_code`, `code`, cùng `redirect_uri` và `code_verifier` của login request. Confidential client xác thực bằng method đã đăng ký.

Token lifecycle

- Dùng OIDC library; callback phải validate `state/nonce`.
- Authorization code dùng một lần; redirect URI phải exact match.
- Refresh token là opaque/reference token có single-use rotation; thay token mới sau mỗi lần refresh.
- Logout gọi `end_session_endpoint` và đồng thời clear local session.
- Không đưa secret hoặc token vào browser log, URL hay source control.

2. API Security - JWT/JWKS

Mục đích: để API/service xác minh access token do EAP cấp trước khi xử lý request và authorize quyền truy cập. OIDC dùng cho login; JWT/JWKS dùng để verify token ở các API/service.

Hạng mục	Contract
Token format	JWT/JWS
Signing algorithm	RS256
Public key endpoint	<code>jwks_uri</code> lấy từ OIDC discovery
Key selection	Dùng JWT header <code>kid</code> để chọn JWK
ID token audience	OIDC <code>client_id</code>
Access token audience	API resource/audience do EAP cấp

Application validate tối thiểu:

- Chữ ký bằng public signing key tương ứng `kid` và algorithm RS256.
- `iss` exact match với EAP issuer.
- `aud` đúng API resource đang gọi; không thay bằng `client_id`.
- `exp` và `nbf`; áp dụng clock skew nhỏ theo cấu hình.
- Với delegated token, kiểm tra thêm delegation claims và local readiness ở mục 4.

Chỉ chấp nhận RS256/RSA signing key; reject none, HMAC algorithm và key không phù hợp. Cache JWKS theo issuer/key ID và refresh khi có key ID mới; không gọi JWKS cho từng request.

3. RabbitMQ - User Sync và Lifecycle

Mục đích: nhận user data và các thay đổi user lifecycle từ EAP để đồng bộ local user/projection của application.

Connection

EAP cấp connection info, runtime credential riêng và ACL theo application/environment. Không dùng broker-admin credential.

Env key gợi ý	EAP cấp	Secret
EAP_RABBITMQ_HOST	Host	Không
EAP_RABBITMQ_PORT	AMQP/TLS port	Không
EAP_RABBITMQ_VHOST	Virtual host	Không
EAP_RABBITMQ_TLS_MODE	TLS policy/certificate requirement	Không
EAP_RABBITMQ_USERNAME	Runtime username riêng của application	Có
EAP_RABBITMQ_PASSWORD	Runtime password	Có

Topology

Direction	Exchange	Queue	Routing key
Consume	eap.user-sync (topic, durable)	<app-user-sync-queue>	user-sync.<clientId>
Consume	eap.identity-events (topic, durable)	<app-identity-events-queue>	Exact keys trong event catalog bên dưới
Publish result	eap.sync-results (direct, durable)	Theo EAP topology	sync-results.identity

EAP cấp queue thực tế, credential, exchange binding và ACL. Queue là queue riêng của application; chỉ bind routing key được cấp.

Event catalog

Event type	Routing key	Application xử lý	EAP result
identity.assigned_users.v1	user-sync.<clientId>	Upsert local user theo userId	Publish Synced/Failed
identity.user_deleted.v1	identity.user_deleted.<clientId>	Disable/soft-delete user; revoke local session/cache theo policy	RabbitMQ delivery ACK sau commit
identity.user_restored.v1	identity.user_restored.<clientId>	Re-enable user theo snapshot mới; không tự cấp thêm role	RabbitMQ delivery ACK sau commit
identity.user_replaced.v1	identity.user_replacement.<clientId>	Transfer/clear access theo mode	RabbitMQ delivery ACK sau commit
identity.role_access_cloned.v1	identity.role_clone.<clientId>	Chỉ xử lý nếu application đăng ký role/access clone	Theo event contract được EAP cấp
identity.delegation_prepare.v1	identity.delegation_prepare.<clientId>	Xem mục 4	Publish Ready/Failed
identity.delegation_cancelled.v1	identity.delegation_cancelled.<clientId>	Xem mục 4	RabbitMQ delivery ACK sau commit

eventType trong message và AMQP routing key là hai giá trị riêng. Không suy ra schema version từ suffix routing key.

Message contract

Common envelope:

```
{
  "eventId": "<guid>",
  "eventType": "identity.assigned_users.v1",
  "eventVersion": 3,
  "occurredAt": "<utc-timestamp>",
  "applicationId": "<application-id>",
  "clientId": "<client-id>",
  "routingKey": "user-sync.<clientId>",
  "idempotencyKey": "<stable-key>",
  "correlationId": "<trace-id>",
  "data": {}
}
```

Assigned user - data:

```
{
  "userId": "<eap-user-guid>",
  "userName": "<username>",
  "email": "<email>",
  "firstName": "<nullable>",
  "lastName": "<nullable>",
  "status": "Active",
  "roles": [],
  "aggregateVersion": 12
}
```

User identity key là `userId`. Email, username, tên hiển thị và role snapshot không thay thế identity key; chỉ áp dụng roles nếu đã đăng ký semantics tương ứng.

Assigned-user result - publish tới `eap.sync-results / sync-results.identity`:

```
{
  "eventId": "<original-event-id>",
  "idempotencyKey": "<original-idempotency-key>",
  "userId": "<eap-user-guid>",
  "applicationId": "<application-id>",
  "clientId": "<client-id>",
  "status": "Synced",
  "processedAt": "<utc-timestamp>"
}
```

status là Synced hoặc Failed; lỗi dùng `errorCode` và `errorMessage` đã sanitize. Result phải echo đúng inbound identifiers. Không đưa secret, token hoặc PII không cần thiết vào error.

User replacement - data:

```
{
  "replacedUserId": "<user-a>",
  "replacementUserId": "<user-b>",
  "mode": "ReplaceWithReplacement",
  "actorUserId": "<operator-id>",
  "source": "<source>"
}
```

mode	Application action
ReplaceWithReplacement	Chuyển access trong replacement scope từ A sang B, disable/inactive A theo policy và lưu audit mapping A → B.
ClearReplacementAccess	Clear/revoke access của B trong replacement scope; không chuyển access của A.

Delivery requirements

```
Consumer MUST be idempotent.
Deduplicate by eventId and/or idempotencyKey.
Apply local change and commit before RabbitMQ delivery ACK.
Apply aggregateVersion only when newer than local state.
```

RabbitMQ delivery ACK chỉ xác nhận broker delivery. Publish business result riêng chỉ cho event có result contract (assigned-user sync và Delegation preparation).

4. Delegation - Required

Mục đích: nhận trạng thái delegation từ EAP và chuẩn bị context để application xử lý request khi một user đại diện cho user khác.

Delegation là EAP-specific contract và là capability bắt buộc. Application tham gia preparation/cancellation lifecycle kể cả khi chưa expose delegated business action.

Rules

Rule	Contract
Schedule	Full-day theo date range; validUntilUtc là thời điểm hết hạn thực tế
Cardinality	Một delegator có tối đa một delegate cho mỗi ngày active
Chain	One level; delegation chain bị reject
Readiness	Chỉ sử dụng context sau khi EAP nhận result Ready đúng version
Cancellation	Revoke local projection/cache và reject delegated request mới
Token exchange	Không dùng OAuth Token Exchange; context thuộc OIDC authorization/refresh flow

Routing keys

Event	Routing key
Preparation	identity.delegation_prep.<clientId>
Cancellation	identity.delegation_cancelled.<clientId>

Preparation contract

Payload data:

```
{
  "delegationId": "<guid>",
  "delegationVersion": 4,
  "delegator": { "userId": "<A>", "userName": "<name>", "email": "<email>" },
  "delegate": { "userId": "<B>", "userName": "<name>", "email": "<email>" },
  "startDate": "2026-09-21",
  "endDate": "2026-09-25",
  "validUntilUtc": "2026-09-26T00:00:00Z",
  "targetClientId": "<clientId>"
}
```

Application lưu projection theo delegationId/delegationVersion/targetClientId, chuẩn bị local context, commit rồi publish result:

```
{
  "eventId": "<original-event-id>",
  "idempotencyKey": "<original-idempotency-key>",
  "delegationId": "<guid>",
  "delegationVersion": 4,
  "clientId": "<clientId>",
  "status": "Ready",
  "processedAt": "<utc-timestamp>"
}
```

status là Ready hoặc Failed. Không publish Ready trước local commit; xử lý duplicate idempotently.

Cancellation contract

Payload data:

```
{
  "delegationId": "<guid>",
  "delegationVersion": 4,
  "delegatorUserId": "<A>",
  "delegateUserId": "<B>",
  "targetClientId": "<clientId>",
  "cancelledAtUtc": "<utc-timestamp>"
}
```

Sau khi cập nhật local projection thành Cancelled/Revoked và invalidate cache, ACK RabbitMQ delivery. Cancellation event không có business result payload trong baseline contract này.

Delegated token claims

Claim	Ý nghĩa
sub	Represented user / business subject (A)
act.sub	Physical actor thực hiện request (B)
delegation_id	Delegation schedule ID
delegation_version	Version cần khớp local projection
delegation_valid_until	Expiry của context

Application authorize delegated request khi signature và standard claims hợp lệ, projection đang Ready/đúng version/chưa bị cancel, context chưa hết hạn; audit riêng actor B và subject A. Không copy grant/role của A sang B.

5. Optional Services

Mục đích: kết nối thêm Notification hoặc Storage khi application có nhu cầu; các capability này không bắt buộc.

Chỉ dùng capability đã được EAP provision cho application/environment.

Notification

Hạng mục	EAP cấp / Contract
Protocol/authentication	HTTP + AWS SigV4
Endpoint	<EAP_NOTIFICATION_BASE_URL>/api/v1/notification/requests hoặc route được provision
Credential	EAP_NOTIFICATION_ACCESS_KEY_ID, EAP_NOTIFICATION_SECRET_ACCESS_KEY
Signing config	EAP_NOTIFICATION_REGION
API access	Resource/audience và scope được EAP cấp/duyet

Request mẫu:

```
POST {EAP_NOTIFICATION_BASE_URL}/api/v1/notification/requests
Content-Type: application/json
Authorization: AWS4-HMAC-SHA256 <sigv4-value>
```

```
{
  "idempotencyKey": "<unique-key>",
  "recipientReference": "<approved-recipient-reference>",
  "content": {
    "channel": "email",
    "subject": "<subject>",
    "htmlBody": "<rendered-html>",
    "textBody": "<optional>"
  },
  "priority": "normal",
  "scheduledAtUtc": null,
  "expiresAtUtc": null
}
```

Response Accepted nghĩa là request đã được nhận/validate, không khẳng định email/SMS/push đã delivery.

Storage

Hạng mục	EAP cấp
Protocol	S3-compatible
Endpoint/bucket	EAP_STORAGE_ENDPOINT, EAP_STORAGE_BUCKET
Backend credential	EAP_STORAGE_ACCESS_KEY_ID, EAP_STORAGE_SECRET_ACCESS_KEY nếu dùng server-side S3
Prefix/permission	EAP_STORAGE_PREFIX, allowed operations
Browser upload/download	EAP_STORAGE_PRESIGN_ENDPOINT hoặc presign flow đã approve
Object policy	private-request-key hoặc public-content-addressed; scanner/result binding

Không cấp static S3 credential cho browser. Chỉ sử dụng object sau khi scanner trả Clean.

Scan result mẫu:

```
{
  "eventType": "object.scan.completed.<clientId>.v1",
  "data": {
    "objectId": "<object-id>",
    "sourceService": "<clientId>",
    "status": "Clean",
    "cleanKey": "<clean-object-key>",
    "publicKey": null,
    "correlationId": "<correlation-id>"
  }
}
```

EAP cấp queue/routing key và scanner output contract cụ thể trong Storage handover.

EAP Gateway/API

Application không bắt buộc đi qua EAP Gateway để dùng OIDC, RabbitMQ, Delegation, Notification hoặc Storage.

Nếu dùng Gateway, EAP cấp:

Configuration	Mục đích
Gateway base URL và route/path	Endpoint public theo environment
Expected audience	Audience của user/service access token
Scope/policy	User scope, service scope, delegated restriction
Destination/health	Backend destination, health path, rate limit
CORS	Origin được allow

Service client và Organization context

- Service client: nếu backend/worker cần gọi API machine-to-machine, EAP cấp client riêng, token endpoint qua OIDC discovery, resource và scope; dùng OAuth `client_credentials`.
- Organization context: nếu cần OU/Department data, EAP cấp API/resource/scope và response contract. Không suy ra thông tin này từ user sync payload.

Environment ownership

- Các value được ghi là EAP cấp/duyệt phải lấy từ Integration Pack theo environment; không tự suy đoán hoặc reuse credential giữa environment.
- Các tên EAP_* ở trên là tên env gợi ý để map configuration, không bắt buộc application phải giữ nguyên tên.
- Application tự quản lý tên và value của local URL, session secret, database và consumer tuning.
- Secret chỉ lưu ở server-side secret manager/configuration an toàn; không commit vào source control.